
PCI DSS v4.0 for NBFC

The cardholder-data protection playbook

From Fresher to Expert, covering card issuance, payment aggregation, tokenization, and the v4.0 customised approach.

What this playbook will make you capable of:

- Explain PCI DSS v4.0 to a non-security CFO in plain English
- Scope the Cardholder Data Environment (CDE) for an NBFC issuing prepaid or credit cards
- Map all 12 requirements + 64 sub-requirements to NBFC-specific evidence
- Build network segmentation, tokenization (RBI aligned), and skimming protections
- Run a 9-month ROC program end-to-end and pass on first attempt
- Choose between Defined Approach and Customised Approach with confidence
- Conduct Targeted Risk Analyses (TRAs) for v4.0 mandatory requirements
- Handle the 2024-2025 v4.0 transition + v4.0.1 script-protection changes

Edition v1.0 | July 2026

Standards covered: PCI DSS v4.0 (March 2022) + v4.0.1 (June 2024), EMVCo 3-D Secure 2.x, RBI Tokenisation Guidelines 2021 + 2023 update, RBI Payment Aggregator Guidelines 2021, RBI Digital Lending 2022, NBFC Master Directions, PCI SSC SAQ family.

Table of Contents

<i>What this playbook will make you capable of:</i>	1
Cardholder-data protection from zero	6
Chapter 1. PCI DSS in two sentences	6
Chapter 2. Why NBFCs specifically deal with PCI DSS	6
Chapter 3. The four PCI DSS levels	6
Chapter 4. The 12 Requirements (v4.0)	7
Chapter 5. Defined Approach vs Customised Approach	8
The 12 requirements, deep-dive with NBFC overlay	9
Chapter 6. Requirement 1 & 2 - Network security controls & secure configurations	9
<i>Req 1 - Network Security Controls (NSCs)</i>	9
<i>Req 2 - Secure Configurations</i>	9
Chapter 7. Requirement 3 - Protect stored account data	9
Chapter 8. Requirement 4 - Protect CHD in transmission	10
Chapter 9. Requirement 5 - Protect from malicious software	10
Chapter 10. Requirement 6 - Develop secure systems & software	10
Chapter 11. Requirement 7 - Restrict access by business need	11
Chapter 12. Requirement 8 - Identify users & authenticate (BIGGEST v4.0 CHANGE)	11
Chapter 13. Requirement 9 - Restrict physical access	12
Chapter 14. Requirement 10 - Log & monitor all access	12
Chapter 15. Requirement 11 - Test security regularly	12
Chapter 16. Requirement 12 - Organizational policies & programmes	13
Chapter 17. Requirement 12.8 - Service Provider matrix (NBFC killer requirement)	13

Chapter 18. NBFC regulatory overlays	14
Running the ROC programme end-to-end	15
Chapter 19. The 9-phase ROC roadmap	15
Chapter 20. Card Data Storage Discovery - the hidden-PAN hunt	15
Chapter 21. Card Data Flow Diagram (CDFD) - build it, get it approved	16
Chapter 22. Targeted Risk Analysis (TRA) template	17
Chapter 23. Scope-shrinking techniques NBFCs use	17
Real NBFC case study & deeply specialised controls	19
Chapter 24. PrepaidPay NBFC Pvt Ltd - the case study	19
Chapter 25. Control-by-control excerpts (PrepaidPay)	19
Chapter 26. NBFC sector must-have controls (the audit essentials)	21
Copy-paste ready artefacts for the ROC programme	22
Template 1. Master Document Checklist (50 documents)	22
Template 2. CDE Inventory (system-by-system)	25
Template 3. Service Provider Register	25
Template 4. Cryptographic Controls Matrix	26
Template 5. ASV Scan Schedule (Quarterly) + ASV Pass Evidence	26
Template 6. Pen-Test Scope & Deliverable List	26
Template 7. ROC Package Deliverables (what your QSA hands over)	27
Template 8. Network Segmentation Test Plan	27
Template 9. Card Data Storage Inventory (PAN-elimination)	27
What QSAs love to find - and what they'll hate	29
Chapter 27. Top 20 findings NBFC services get	29
Chapter 28. Pro tips - 30 habits that win ROC audits	30

Fieldwork: the 14-day march to ROC issuance

Chapter 29. Day -14: audit readiness check

Chapter 30. Fieldwork rituals

Chapter 31. Findings + Management Response

15 questions for PCI-anchored NBFC interviews

Q1. PCI DSS in one sentence.

Q2. Name 4 of the 12 requirements.

Q3. PAN storage rule golden principle.

Q4. RBI Tokenisation.

Q5. 8.4.2 (MFA all access into CDE).

Q6. ASV vs Pen-test.

Q7. ROC issuance for NBFC.

Q8. Service Provider responsibility.

Q9. TRA - what is it?

Q10. Skimming protection.

Q11. Segregation of CDE.

Q12. Card Vault technically.

Q13. ASV fail mitigation.

Q14. P2PE.

Q15. NBFC RBI + PCI alignment.

GLOSSARY - 60 PCI DSS TERMS TO OWN

32

32

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

Cardholder-data protection from zero

Chapter 1. PCI DSS in two sentences

Payment Card Industry Data Security Standard (PCI DSS) is the contractual obligation every entity that stores, processes, or transmits cardholder data (CHD) must comply with. Maintained by the PCI Security Standards Council (PCI SSC), v4.0 replaced v3.2.1 effective 31 March 2024 for service providers and 31 March 2025 for merchants.

- **SIX core objectives** that map to the 12 requirements: Build & Maintain a Secure Network, Protect Account Data, Maintain a Vulnerability Management Program, Implement Strong Access Control Measures, Regularly Monitor & Test Networks, Maintain an Information Security Policy.
- **Validated by:** Qualified Security Assessor (QSA) for Service Providers & Level 1 merchants; Internal Security Assessor (ISA) for some merchants; Self-Assessment Questionnaire (SAQ) for eligible smaller merchants.
- **Penalty for non-compliance:** Contractual fines from card networks (■■■■), loss of ability to process cards, breach liability shift onto the non-compliant entity, reputational harm.

Chapter 2. Why NBFCs specifically deal with PCI DSS

RBI classifies NBFCs into multiple layers (NBFC-MFI, NBFC-ICC, NBFC-Factor, etc.). Any NBFC that issues cards, runs a payment aggregator / gateway, or even collects loan repayments via debit/credit card compliant rails has card data flowing through. Once card data flows, PCI DSS applies. RBI additionally overlays tokenisation, storage restrictions on Card-on-File data, and PA/PG licensing.

that trigger PCI DSS

- co-branded credit card with HDFC Bank or ICICI Bank - PCI DSS Level 1 (highest).
- Payment Aggregator (PA) - RBI PA 2020 license required + PCI DSS Service Provider Level 1.
- Prepaid Payment Instrument (PPI) wallet - PCI DSS Level 1 as wallet operator.
- EMI via cards through Razorpay/Cashfree - merchant Level 2 typically.
- Card-based personal loan product with PIN-on-card verification - PCI DSS scope extends to PIN handling.
- Tokenised cash-back/redemption per RBI Tokenisation Guidelines - still touches PAN so in-scope.

Chapter 3. The four PCI DSS levels

Level	Volume	Validation mechanism
Level 1	>6M Visa/MC transactions/year OR any Service Provider that stores/processes cardholder data	Annual Report on Compliance (ROC) by QSA + quarterly ASV scan + penetration test
Level 2	1M-6M Visa/MC/year (e-commerce or brick & mortar)	Annual SAQ by eligible merchant OR ROC; quarterly ASV
Level 3	20K-1M e-commerce OR 1M+ non-e-commerce	Annual SAQ (A or A-EP); quarterly ASV
Level 4	<20K e-commerce OR <1M non-e-commerce	Annual SAQ; quarterly ASV (recommended)

st will be Service Provider Level 1

bracket. It demands annual QSA-led ROC, quarterly ASV scan by PCI SSC-approved ASV, annual penetration test, internal vulnerability scans (authenticated), file integrity monitoring (FIM) or
nted information security policy programme. Budget ■1.5-3 crore for first-year compliance, ■80-150 lakh for ongoing annual maintenance.

Chapter 4. The 12 Requirements (v4.0)

#	Requirement headline
1	Install and maintain network security controls
2	Apply secure configurations to all system components
3	Protect stored account data
4	Protect cardholder data with strong cryptography during transmission
5	Protect all systems and networks from malicious software
6	Develop and maintain secure systems and software
7	Restrict access to system components and cardholder data by business need
8	Identify users and authenticate access to system components
9	Restrict physical access to cardholder data
10	Log and monitor all access to system components and cardholder data
11	Test security of systems and networks regularly

12	Support information security with organisational policies and programmes
----	--

Chapter 5. Defined Approach vs Customised Approach

v4.0 introduced two compliance approaches. You must state which one each requirement uses.

Aspect	Defined Approach (DA)	Customised Approach (CA)
How you comply	Implement the exact requirement and defined testing as written	Meet the Customised Approach Objective (CAO) using your own controls - must demonstrate
Evidence format	Pre-defined testing procedures; auditor ticks boxes	Mature risk analysis + own control matrix + compensating justifications
Audit cost	Lower; predictable	Higher; QSA debates rigour each year
When to use	Default for first-time PCI implementations	When strict DA impossible (e.g., legacy mainframe); mature organisations with QSA b
NBFC fit	Almost always - simpler, faster, cheaper	Rarely; only if card data flow is on legacy AS/400 or unique architecture

Analysis (TRA) - new in v4.0

Requirements (3.5.1.1, 3.6.1.1, 4.3.1, 5.4.1, 7.2.4.1, 8.3.3, 8.6.1, 10.2.1.2, 11.3.1.2, 11.6.1.1, 12.3.1.1) require a Targeted Risk Analysis. NBFC should adopt a TRA template now - this is the new approach. A TRA records: asset, threat, risk score, control, review cadence, re-analysis trigger.

TRA - the Indian angle you cannot skip

Tokenisation Guidelines (Sep 2021, May 2023 update) banned storage of actual PAN by merchants from 30 Jun 2022 onwards (extended). NBFCs processing recurring card transactions must use Token Service, Mastercard MDES, RuPay Token Vault). This **does NOT take you out of PCI DSS scope** - token requestor still handles PAN momentarily - but **drastically reduces scope** if you implement it correctly.

The 12 requirements, deep-dive with NBFC overlay

Chapter 6. Requirement 1 & 2 - Network security controls & secure configurations

Req 1 - Network Security Controls (NSCs)

- **1.1** Documented processes & policies for NSCs.
- **1.2** NSCs configured and maintained; ruleset reviewed every 6 months.
- **1.3** NSCs installed between trusted/untrusted networks.
- **1.4** NSC configuration of trusted segments; rules restricting inbound/outbound; default-deny.
- **1.5** Restrictions on NSC admin access (least privilege, MFA, audit log).
- **NBFC overlay:** Card Vault must be in its own segment; POS terminals on segregated VLAN; on-prem PIN pads out of data network.

Req 2 - Secure Configurations

- **2.1** Documented configuration standards for all system components.
- **2.2** Vendor-supplied defaults are managed (no default admin/admin passwords).
- **2.3** Wireless environments use WPA3 / strong encryption with unique passwords.
- **NBFC overlay:** All switches / routers hardened; syslog to SIEM; configuration backups in secured repo with integrity check.

segmentation - the single biggest scope-reducer

segmentation, ENTIRE corporate network is in PCI scope. With a correctly-segmented CDE (Cardholder Data Environment) - usually a separate VPC with its own firewall ACL - scope is drastically reduced.
→ WAF → DMZ → Tokenisation Vault → back-end services → issuer. DOCUMENT the segmentation with a network diagram QSA can read in 5 seconds.

Chapter 7. Requirement 3 - Protect stored account data

- **3.1** Account data storage is restricted to a justified business need.
- **3.2** Sensitive Authentication Data (SAD) NOT stored after authorisation - this includes full track, CVV/CVV2, PIN/PIN block.
- **3.3** PAN is masked when displayed (max first 6 + last 4 visible).
- **3.4** PAN is unreadable wherever stored - encryption, tokenisation, truncation, hashed, etc.

- **3.5** Cryptographic keys used to protect PAN are secured.
- **3.6** Cryptographic key management lifecycle (generation, distribution, storage, rotation, retirement).
- **3.7** Where PAN is rendered unreadable via hash, use keyed cryptographic hash with appropriate salt/input.

- HARD STOP

Full magnetic stripe data, CVV/CVV2, PIN, PIN block - **are forbidden to be stored** ever. Most common PCI attributions result from this. Delete them from logs, temp files, education/demo data, dashboards. Read this clause ten times.

& 3.6 - Cryptographic key management

Where is your HSM used?. For an NBFC issuing cards on its own BIN, you need **Thales / Entrust / AWS CloudHSM (FIPS 140-2 Level 3)** storing card-related keys. RBI PCI mandates HSM-grants. Document key hierarchy: Zone Master Key (ZMK) → Zone PIN Key (ZPK) → PIN Encryption Key (PEK). Show key rotation annually, dual-control split knowledge.

Chapter 8. Requirement 4 - Protect CHD in transmission

- **4.1** Strong cryptography and security protocols safeguard PAN during transmission.
- **4.2** PAN is never sent via unprotected channels (SMS, email, chat, etc.).
- **4.3** TRA mandated for cryptographic transmission controls (new in v4.0).
- **NBFC overlay:** TLS 1.2 minimum, RFC 8484 (TLS 1.3) preferred. Card-on-File tokenised via Visa Token Service (VTS), MDES, RuPay Token Vault.

Chapter 9. Requirement 5 - Protect from malicious software

- **5.1** Anti-malware solution on all systems commonly affected (includes Linux servers and cloud workloads).
- **5.2** Anti-malware kept current, periodic scans, audit logs of events.
- **5.3** Anti-malware not user-disabled.
- **5.4** Phishing protections installed & maintained (new in v4.0; multi-pronged anti-phishing tech).
- **NBFC overlay:** EDR everywhere (CrowdStrike, SentinelOne, Defender); email security (Proofpoint/Mimecast/Avanan); anti-phishing banners; DMARC enforcement.

Chapter 10. Requirement 6 - Develop secure systems & software

- **6.1** Processes to identify and assign security vulnerabilities; ranking per risk.

- **6.2** Vendor-supplied patches installed within one month of release for critical components.
- **6.3** Software development lifecycle with security baked in.
- **6.4** Public-facing web applications additionally protected (WAF or code-level).
- **6.4.3** (NEW v4.0.1, 2025) Payment page scripts are inventoried + authorised + integrity-controlled. Skimming-defence.
- **6.5** Pre-production code is NOT deployed to production without strict change control.

3 (v4.0.1, due Mar 2025) - script skimming defence

On a payment page or any in-app card data entry, you **MUST**:

Inventory (all JS files loaded during checkout),

Authorise each script,

Integrity via integrity hashes (Subresource Integrity SRI),

Detection on the page (Magecart-style eSkimming defences).

Client-Side Protection, Source Defense, Jscrambler, PerimeterX HUMAN Security.

Chapter 11. Requirement 7 - Restrict access by business need

- **7.1** Access to system components and CHD is restricted to least privilege.
- **7.2** Access assignment is via role (RBAC), with documented access control models.
- **7.3** Default-deny on access control systems.
- **NBFC overlay:** RBAC for POS agent onboarding teams, customer support seeing card details, fraud analysts needing PAN. 'Masked PAN' role vs 'Full PAN' role strictly controlled.

Chapter 12. Requirement 8 - Identify users & authenticate (BIGGEST v4.0 CHANGE)

- **8.1** Unique user IDs assigned; shared accounts prohibited.
- **8.2** Identification & authentication policies documented.
- **8.3** Authentication factors meet strong-crypto guidelines; MFA for ALL access into CDE (previously just admin).
- **8.4** User authentication credentials & account management.
- **8.5** Multi-factor authentication applied (Mandatory for ALL access into CDE - yes, even end-user access via customer service portal).
- **8.6** Service accounts, application & system accounts authentication.

- **NBFC overlay:** For customer-facing portals touching card data: implement 3DS2 challenge flow, soft-token OTP, RBI mandated PIN-less SMS confirmations, and 2FA for any 'view card details' action.

2 - MFA EVERYWHERE into CDE was v4.0 game-changer

was required only for administrative access into CDE. **v4.0 mandates MFA for ALL access into CDE** (8.4.2 applies as a defined approach; future-dated best practice becomes mandatory). In a customer service portal viewing card tokens, MFA on agent terminal accessing card data, MFA on partner co-issuer administrator console.

Chapter 13. Requirement 9 - Restrict physical access

- **9.1** Physical access controls to CDE facilities (badge, biometrics, mantraps).
- **9.2** Visitor management; escort policy.
- **9.3** Physical access for personnel - reviewed quarterly for offices handling CHD.
- **9.4** Media with CHD is securely stored, distributed, destroyed.
- **9.5** Point-of-interaction (POI) devices are inventoried, inspected, secured.
- **NBFC overlay:** Your data centres, POS / PIN pad security, and card-personalisation facilities (if any) are physical security audit targets.

Chapter 14. Requirement 10 - Log & monitor all access

- **10.1** Audit logs are enabled for all CDE components.
- **10.2** Audit logs record user identification, event type, datetime, success/failure, origination, affected component.
- **10.2.1.2** TRA required for audit log review cadence.
- **10.3** Audit logs are protected from tampering & unauthorised modifications; 12 months minimum (3 months online, 9 months archived).
- **10.4** Logs are reviewed daily (security events), weekly (other components).
- **10.5** Audit log history retained and regularly tested for integrity.
- **10.6** Time-synchronisation mechanism across all systems.
- **10.7** Failures of critical security controls are detected, alerted, addressed.
- **NBFC overlay:** SIEM rules specifically for transaction patterns, abnormal admin login on card vault, anomalous POS behaviour.

Chapter 15. Requirement 11 - Test security regularly

- **11.1** Documented processes for vulnerability detection.

- **11.2** Wireless access points are identified and monitored.
- **11.3** Internal vulnerability scans quarterly + after significant change; rescan after high-risk vuln remediation.
- **11.3.1.2** Authenticated internal scans - scanner uses credentials to authenticate to systems.
- **11.4** External vulnerability scans - quarterly by PCI SSC-approved ASV; passing scan achieved.
- **11.5** File integrity monitoring (FIM) on critical files; weekly comparison; alerts for unauthorised change.
- **11.6.1** (NEW v4.0.1) Payment page change- and tamper-detection mechanism installed; quarterly alert review.
- **11.7** Network intrusion detection / prevention; placed at perimeter + critical points.
- **NBFC overlay:** Pen-test (annual) must cover both internal + external + segmentation testing. Web app pen-test every quarter for payment pages.

-test - distinguish these often-confused terms

al vulnerability scan from PCI SSC-approved ASV vendor (Trustwave, Qualys, CyberOxide, etc.). Quarterly. Zero 'Critical' required to pass.

+ tool-based exploitation attempt by skilled pentester. Annual for Level 1. Tests both internal, external, and **segmentation effectiveness between CDE and corporate network**.
y. Auditors will ask for both ASV pass ATR letter AND full pen-test report.

Chapter 16. Requirement 12 - Organizational policies & programmes

- **12.1** Comprehensive information security policy; reviewed annually + on changes.
- **12.2** Acceptable use policies for end-user technologies including mobile.
- **12.3** Risks to cardholder data formally identified, assessed, managed.
- **12.3.1** Service providers maintain an up-to-date list; written agreement with each service provider acknowledging responsibility for security of cardholder data the SP stores/processes/transmits.
- **12.4** Compliance & security responsibilities identified; PCI DSS compliance programme managed.
- **12.5** PCI DSS scope documented; documented inventory of CDE components, including third-party.
- **12.6** Security awareness education on hire + at least annually.
- **12.7** Potential personnel are screened prior to hire.
- **12.8** Service providers support customers' PCI DSS compliance + manage their own compliance.
- **12.9** Service providers acknowledge responsibility.
- **12.10** Suspected or confirmed security incidents responded to in a timely manner.

Chapter 17. Requirement 12.8 - Service Provider matrix (NBFC killer requirement)

You must maintain a written agreement with every service provider that stores, processes, or transmits cardholder data on your behalf, OR could impact the security of CHD. The agreement must acknowledge the SP's responsibility.

- Maintain a register of SPs.
- Each SP must sign a written agreement acknowledging responsibility for CHD security.
- Each SP must provide evidence of PCI DSS compliance (their own AOC or AOC cut-down for you).
- Quarterly review of the SP list.
- Termination process to remove CHD from SP environment at contract end.

Chapter 18. NBFC regulatory overlays

Regulator / Act / Network	Clause	What NBFC must do
RBI Master Direction - NBFC Master Direction Cyber Security Framework 2023	Cyber security	Apply cyber security framework + parallel card-data controls
RBI Tokenisation Guidelines 2021 + 2023	CoF storage / tokenisation	No store of actual PAN; use token for recurring transactions; support networks' token services
RBI Payment Aggregator 2020	PA licensing	Licence before operating; PCI DSS ROC before commencement
RBI Digital Lending 2022	Card-based digital lending	Disclosures; partner risk assessment; data minimisation; FPC standard
EMVCo 3-D Secure 2.x	Cardholder authentication at e-commerce	Implement 3DS2 for online card transactions; frictionless flow validation
Visa/Mastercard/RuPay	Network rules	Visa Core Rules & Visa Product Brand Guide; Mastercard Site Data Protection (SDP); RuPay To
PCI PTS (PIN Transaction Security)	POI & PED approval	PIN pads must be PTS v6 approved; HSM must be PCI HSM v4
CERT-In Directions 2022	Incident notification 6h	Same as SOC 2 - apply to card data incidents

Running the ROC programme end-to-end

Chapter 19. The 9-phase ROC roadmap

Phase	Weeks	Activities
1. Mobilise	0-2	Charter, sponsor (CTO/CISO/CFO), QSA selection (Big 4 / mid-tier), Steering Committee. Engagement letter signed.
2. Card Data Discovery	2-6	Card data flow diagram, card data storage discovery (including hidden places), CDE network re-trace.
3. Scope Decision	4-8	CDE scope agreed with QSA; segmentation test plan; CDE-included systems, CDE-connected systems, out-of-scope systems.
4. Gap Assessment	6-12	Walk through 64 sub-requirements; track status Open / In Progress / Approved. TRA workshops run.
5. Remediation	8-26	Implement missing controls. Tokenisation, HSM, MFA, FIM, logging, scripts inventory, anti-phishing. Documentation of every policy.
6. Pre-ROC	26-30	Internal dry run; ROC template filled (the matrices); QSA walk-through; sample evidence staging.
7. ROC Fieldwork	30-38	QSA interviews, evidence requests, on-site (or virtual) visits, sample pulling, ROC report drafting.
8. ROC Issuance	38-44	QSA's Report on Compliance (ROC) + supportive Attestation of Compliance (AOC); filing with acquirer/issuer.
9. Maintenance	44+	Quarterly ASV scan cycle, annual penetration test, annual recertification, dashboard maintenance, monthly reviews.

Chapter 20. Card Data Storage Discovery - the hidden-PAN hunt

PAN must not be stored anywhere except the card vault. NBFC's most common disclosure is finding PAN in unlikely places - log files, debug outputs, screenshots, junior dev's laptop. Run a PAN discovery project before ROC fieldwork.

Source	Tool	Risk
Databases (RDS, Aurora, Mongo, Redis)	AWS Macie, custom regex grep via GuardDuty Sensitive Data	Highest
Data lake / Snowflake / BigQuery	BigQuery DLP, Snowflake column-level scanning	Highest
S3 buckets (incl. backups, exports)	Macie + custom script regex	Highest
Application log streams (CloudWatch, Splunk)	Custom regex + SIEM rules	High
Email / Slack / Teams messages	CASB + regex context scan	Very High

Developer laptops / desktops	EDR + custom regex audit scripts	High
Mobile app crash logs / analytics	Mobile DLP + FinClip / AppShield	High
Backup archives (Glacier, on-prem tapes)	Off-host scanning + cloud restore & scan	High
Third-party (collection agencies, recovery agencies)	Vendor audits + data deletion certificates	Medium

Chapter 21. Card Data Flow Diagram (CDFD) - build it, get it approved

A CDE-shaping artefact. Aim: every auditor, new joiner, and infrastructure person can read it in minutes.

Element to draw	What it represents
Cardholder entry points	POS terminals, mobile checkout, e-commerce checkout, IVR, customer service
Egress from entry	Load balancer → API Gateway → Micro-services
Data at rest store	Card Vault, HSM (PIN ops), backups
Tokenisation point	VTs / MDES / RuPay integrator
Card processor / Acquirer integration	Eazypay, CyberSource, etc.
Internal consumers of masked PAN	Reporting, fraud analytics, customer support
Outbound flows	Ledger/posting, analytics warehouses, regulator reporting
Boundary / NSC lines	Firewalls, NACLs, ASGs
Service providers in scope	Hosting, KMS, tokenisation, fraud screening, payment gateway

mb

30-lane diagram. **Two diagrams max:** a 'card entry to vault' and a 'card vault to outs'. Use swim-lanes by store, application, scope (CDE vs connected-to vs out-of-scope). Every arrow: label (truncated PAN, token, masked token).

Chapter 22. Targeted Risk Analysis (TRA) template

Field	Value
Requirement reference	e.g. 11.6.1
Customised Approach Objective	Quote from PCI DSS v4.0 document
Asset / system in scope	Description
Threat scenario	e.g. Skimming via malicious script injection
Likelihood (1-5)	Score
Impact (1-5)	Score
Risk score	$L \times I$
Controls implemented	List (technical + procedural)
Residual risk	Re-score after controls applied
Review cadence	e.g. quarterly OR after incident
Re-analysis trigger	e.g. change to payment page, new 3rd party
Owner	Name + role
Approver	CISO
Date last reviewed	Date

Chapter 23. Scope-shrinking techniques NBFCs use

Technique	Effect
Tokenisation	Replace PAN with token; only tokenisation engine has access to vault
Outsourcing to P2PE validated provider	Encrypts at point of interaction (P2PE); PAN never enters your environment
Network segmentation (CDE VPC isolated)	Cuts scope to a defined enclave
Truncation (last-4-only storage)	Disqualifies data from being 'cardholder data'
Hosted payment pages (checkout web iframe)	Card data never touches your server - checkout.js hosted by Stripe/Razorpay etc.

RBI tokenisation strategy	Visa TSP, Mastercard MDES, RuPay ISV; reduces PCI DSS involvement
Clearinghouse-only role	If you only settle, no storage; much smaller footprint

Real NBFC case study & deeply specialised controls

Chapter 24. PrepaidPay NBFC Pvt Ltd - the case study

Profile: PrepaidPay is a PPI-licensed (Prepaid Payment Instrument) NBFC-ICC under RBI, founded 2017, 350 employees, HQ Pune. Operates a closed-loop digital wallet + co-branded Visa prepaid cards issued in partnership with a co-issuer bank. Card volume: 2.6M active cards; transaction volume: ~430M transactions/year; total PAN stored: ~2.6M card records.

Engagement: PCI DSS v4.0 ROC for Service Provider Level 1. Top-tier QSA firm. Total sub-requirements tested: 64 (Defined Approach). CDE = 38 systems (RDS-encrypted vault, KMS, CloudHSM, 12 microservices, payment processor integration, mobile SDK endpoints).

Why this worked: (1) RBI tokenisation chosen upfront to minimise CDE footprint, (2) P2PE certified POS devices for retail, (3) Network segmentation since day 1 (no expansion of CDE), (4) TRA discipline applied across 11 v4.0 requirements.

... - the single best decision

...d to tokenise every PAN at issuance time reduced PrepaidPay's storage of actual PAN to ≤ **8,000 records** (issuance master vs loaded cards). QSA could mark Req 3.1 as 'Restricted to issuance' to reduce complexity.

Chapter 25. Control-by-control excerpts (PrepaidPay)

... / 3.5 - Card vault encryption

...t rest stored in Aurora PostgreSQL column-level encrypted via AWS KMS CMK with key rotation annually. Key hierarchy: Customer Master Key (CMK) — quarterly rotation; Data Encryption Key (DEK) — annually via AWS CloudHSM (FIPS 140-2 L3), P2PE.

...y inventory, rotation logs, CloudHSM attestation, Aurora encryption config export, key ceremony record with dual control / split knowledge.

...sted 30 records — encryption verified via KMS re-invoke; CloudHSM serial + attestation report verified at slot-level.

3 / 11.6.1 - Script skimming defence

of all scripts loaded onto the payment page in production; manifest format (subresource integrity SRI hashes); automated header check during CI/CD; weekly Subresource Integrity & Content Client-Side Protection; tamper alerts wired to PagerDuty within 1 minute.

2026 — Akamai found a vendor SDK attempting to load an inline script that wasn't authorised; automated block + analyst invoked within 4 min. QSA cited this as evidence of operating effectively to show real alert closure.

Having the alert + SOC run-book + RCAs in the audit window was smart — anecdotal evidence reinforces true compliance.

2 - MFA on all access into CDE

Dokta + WebAuthn (FIDO2 phishing-resistant). Account recovery via out-of-band hardware token; no SMS OTP fallback.

8.4.2 / 8.5 / 8.6 (service accounts): All 280 service accounts rotated credentials via AWS Secrets Manager; 200% time-bound; currently via IAM Roles Anywhere for inter-service. No long-lived keys.

praised no-CLI-keys posture; scratch cards for human service account rotation in 2025-Q4 dip.

Quarterly ASV + annual pen-test + FIM

stwave (PCI SSC-approved). Quarterly scan via Qualys Cloud Platform. Pen-test: NCC Group annual; segmentation test included. FIM: Tripwire on 38 CDE hosts; weekly baseline comparison to detect changes.

ss ATR certificate (all 4 quarters); pen-test report; Tripwire change log; SIEM alert closure tickets.

Configured FIM spinning too many alerts on /var/log rotation; we added whitelist; QSA flagged stale whitelist as issue; we re-included with TRA backing.

3 - Service provider register + written agreement

provider register of 22 SPs; each with Signed Master Services Agreement (MSA) including clause acknowledging responsibility for CHD; each SP's AOC filed annually. Quarterly CISO reviews register.

ection agency vendor (high-risk) had its AOC expire for 23 days. Mitigation: paused card-on-collect flow until fresh AOC received; documented exception; auditor accepted because it was self-reported.

ual draw-backs — speak to these honestly

ur 'CRL caching' approach for cert revocation; we had to swap to OCSP stapling + short-lived certs.

K held CDE keys for asynchronous retry — we had to refactor to use tokenisation on every retry, full Token-on-Device.

ds stale for some new joiners in field-ops; we had to retro-document the 12-month refresher cycle for 11 personnel — auditor says this was the single biggest bump in fieldwork.

Chapter 26. NBFC sector must-have controls (the audit essentials)

Area	What you must have
Card vault	PAN encrypted, separate from corporate VPC, restricted access, KMS-managed.
HSM for PIN	PCI HSM v4 approved hardware. Or P2PE encrypted terminal chain.
Tokenisation	Universal token support across Visa/MC/RuPay; multiple token requestors if needed.
3DS2	Mandatory for e-commerce transactions; minimal friction.
Script inventory + tamper detection	Akamai / Human / Source Defense deployed + monitored.
MFA into CDE	All access, including user-facing agent portal.
Quarterly ASV	From PCI SSC-approved ASV; fail → remediated → rescan inside 30 days.
FIM + IDS	Tripwire / OSSEC + signature-based IDS at perimeter + critical points.
Service provider register	Quarterly CISO review; AOC expiry calendar.
Penetration testing	Annual + segmentation test + payment-page quarterly test.
Log retention	3 months online + 9 months archived, 12 months minimum. SIEM + immutable storage.
Personnel screening	BGV for ALL CDE-involved roles; document retention 5 years.
Physical security	Data center badge + biometric + 24/7 guards; quarterly walk-through review.
Incident response	Same as SOC 2 + card-network 24-hour breach notification clauses.

Copy-paste ready artefacts for the ROC programme

Template 1. Master Document Checklist (50 documents)

#	Document	Owner
1	Information Security Policy	CISO
2	Acceptable Use Policy	CISO
3	Cardholder Data Protection Policy	CISO + Compliance
4	Card Data Storage & Retention Policy	CISO
5	Cryptographic Key Management Policy	Crypto Lead + CISO
6	Cryptographic Standards Document	Crypto Lead
7	Access Control Policy (NBFC-PCI specific)	CISO
8	Authentication Policy (MFA)	CISO + IT
9	Network Security Policy	Network Lead + CISO
10	Firewall / NSC Rule-set Procedure	Network Lead
11	Secure Configuration Standards (Linux, Win, network devices)	Infra
12	Patch Management Policy	Infra
13	Anti-Malware Policy	CISO
14	Anti-Phishing Programme Document	CISO + IT
15	System Development Life Cycle (SDLC) Policy	CTO
16	Secure Coding Standards	CTO
17	Payment Page Script Inventory Register	App Sec + Web Lead
18	Payment Page Integrity Monitoring Procedure	App Sec
19	Change Management Policy	Engineering
20	Logging & Monitoring Policy	CISO + SOC
21	Audit Log Review Procedure (daily/weekly/monthly)	SOC

22	Time Synchronisation Procedure	Infra
23	Vulnerability Management Policy	CISO
24	ASV Scan Procedure (Quarterly)	SecOps
25	Internal Vulnerability Scan Procedure	SecOps
26	File Integrity Monitoring Procedure	SecOps
27	Wireless & Rogue Device Detection	SecOps
28	Penetration Test Charter	App Sec
29	Physical Security Policy (Data Center)	Facilities + CISO
30	Visitor Management Procedure	Facilities
31	POI / POS Device Inventory Template	Operations
32	Media Handling & Destruction Procedure	IT + Facilities
33	Background Verification Policy	HR + Compliance
34	Security Awareness Training Policy	CISO + HR
35	Acceptable Use - Mobile	CISO
36	Personnel Security Policy	HR + CISO
37	Service Provider Management Policy	CISO + Procurement
38	Service Provider Register	Compliance
39	Service Provider MSA with PCI acknowledgement clause	Legal + Compliance
40	Incident Response Plan (PCI specific)	CISO
41	Incident Response Run-books (P1-P4)	SOC
42	Business Continuity Plan (CDE included)	CIO + CISO
43	Risk Assessment Methodology	CRO + CISO
44	Cardholder Data Discovery Procedure	CISO
45	Card Data Flow Diagram (CDFD)	CISO + Eng
46	Targeted Risk Analysis (TRA) Templates	CISO
47	PCI DSS Compliance Programme Summary	Compliance
48	Annual Compliance Maintenance Schedule	Compliance
49	Quarterly Compliance Dashboard	Compliance + CISO

50

ROC Report (QSA produced)

QSA

Template 2. CDE Inventory (system-by-system)

Asset ID	Component	Type	Function	PAN access	Owner	Last review
CDE-001	Aurora PostgreSQL Card Vault	DB	Primary PAN store	R/W	DBA	Jan-2025
CDE-002	AWS KMS CMK Cluster	KMS	Envelope keys for vault	via DEK	Crypto	Mar-2025
CDE-003	AWS CloudHSM Cluster (PCI HSM v4)	HSM	PIN ops & key custody	via API	Crypto	Feb-2025
CDE-004	Auth Service (Okta + WebAuthn)	App	Authentication	none	IAM	Apr-2025
CDE-005	Card Service	App	Card lifecycle	R	Eng	Mar-2025
CDE-006	Tokenisation Service (VisaTS adapter)	App	PAN↔Token	yes (transient)	Eng	Mar-2025
CDE-007	Payment Gateway Egress Adapter	App	Sends to processor	decrypted	Eng	Feb-2025
CDE-008	Inbound WAF	Network	Edge	n/a	Net	Apr-2025
CDE-009	POS Device Fleet	POI	Acceptance	transient (P2PE)	Operations	Monthly
CDE-010	Mobile SDK (issuer-side)	SDK	Card data entry	transient	Mobile Eng	Mar-2025
CDE-011	Customer Service Portal	App	View card details	read	CS Eng	Feb-2025
CDE-012	Reporting & Analytics	App	Masked PAN reporting	masked	Bi Eng	Apr-2025

Template 3. Service Provider Register

SP ID	Service Provider	Service	PAN Touch	PCI Level	AOC valid until	Risk
SP-001	AWS India	Hosting + KMS	Indirect	Level 1	30-Sep-2025	Low
SP-002	Visa Token Service	Tokenisation	Transient	Level 1	31-Dec-2025	Low
SP-003	Mastercard MDES	Tokenisation	Transient	Level 1	31-Dec-2025	Low
SP-004	Razorpay (PA)	Payment gateway	Transient	Level 1	30-Sep-2025	Low
SP-005	Bajaj Finance co-issuer	Card issuance	Yes (issuance)	Level 1	31-Aug-2025	Med
SP-006	Pine Labs (P2PE)	POS / P2PE	No (P2PE)	P2PE v3	30-Nov-2025	Low
SP-007	SteelEye (AML / FRM)	Transaction monitoring	No	n/a (no PAN)	n/a	Med
SP-008	Signzy (KYC)	eKYC	No	SOC 2	31-Aug-2025	Med
SP-009	Cashfree (collect-out)	Payment gateway	Transient	Level 1	31-Dec-2025	Low

Template 4. Cryptographic Controls Matrix

Purpose	Algorithm/key	Length	Storage	Lifecycle	Standards
PAN encryption at rest (DB column)	AES-GCM-256 with KMS DEK	256	AWS KMS HSM-backed CMK	Annual rotation	NIST SP 800-38D / FIPS 197
PIN block encryption (issuer → network)	AES-256 + ISO 9564 format 1/2/3	256	CloudHSM (PCI HSM v4)	Annual rotation, dual control	PCI HSM v4 / ISO 9564
Network segmentation keys (IPsec)	AES-256-GCM	256	AWS KMS + Cloud HSM	Quarterly	NIST SP 800-77 / RFC 4309
Public-facing TLS termination	TLS 1.3 (AES-128-GCM-SHA256+ECDHE)	ECDHE P-256/RSASSA-PSS min	AWS ACM	Annual cert renewal with rotation	RFC 8446
Mobile SDK ↔ server channel	TLS 1.3 + cert pinning	Same as above	Pinned at build	Annual	OWASP MASVS
Card-token mapping (PAN→Token)	HMAC-SHA-256 deterministic token derivation	256	Tokenisation engine	Re-issue only on PAN change	EMVCo Payment Tokenisation Specification
POI PIN entry (P2PE)	Vendor-managed (PCI P2PE v3)	Vendor	Vendor HSM	Vendor rotation	PCI P2PE v3.0

Template 5. ASV Scan Schedule (Quarterly) + ASV Pass Evidence

Quarter	Date	Vendor	Pass? (y/n)	Re-scan date	ATR on file?
Q1-2025	15-Jan-2025	Trustwave India	Pass (after 2 re-scans)	21-Feb-2025	Yes
Q2-2025	12-Apr-2025	Trustwave India	Pass	n/a	Yes
Q3-2025	10-Jul-2025	CyberOxide (PCI SSC)	Pass	n/a	Yes
Q4-2025	08-Oct-2025	CyberOxide (PCI SSC)	Pass	n/a	Yes

Template 6. Pen-Test Scope & Deliverable List

Pen-test artefact	Audience	Cadence
External network penetration test report	QSA + bank co-issuer + acquirer	Annual
Internal penetration test report	QSA	Annual
Segmentation test report (CDE vs corporate)	QSA (Req 11.4.5-disconnect after v4.0)	Annual
Web application penetration test report (payment pages)	QSA	Annual + on material change
Mobile application penetration test report (issuer + consumer)	QSA	Annual
API penetration test report	QSA + internal AppSec	Bi-annual
Red-team exercise report (optional)	QSA + executive sponsor	Optional

Template 7. ROC Package Deliverables (what your QSA hands over)

Deliverable	What it contains
Report on Compliance (ROC)	Auditor's testing of every Defined Approach control with results
Attestation of Compliance (AOC)	Auditor-signed compliance statement
Compliance Worksheet (CoW)	Detailed evidence references per requirement
Service Providers RoC receipt list	AOCs taken from each in-scope SP
QSA Engagement Letter	Scope, period, fee, responsibilities
Master Service Agreement + Addendum	Your service contract + addendum with QSA
Acquirer / Card Network Filing	The AOC filed with each card network

Template 8. Network Segmentation Test Plan

Step	Action	Pass criterion
1	Identify all CDE systems via inventory	All in-scope systems cataloged
2	Identify all 'connected-to' systems (provisioning, monitoring, jump boxes)	Documented list
3	Map all network paths: corporate ↔ connected-to ↔ CDE	Network diagram with all NSCs labelled
4	Pen-test target: corporate-to-CDE exposure, jump-host hardened paths	Pen-tester cannot reach CDE from corporate via exploit
5	Compensating test: legitimate credentialed access still possible	Approved RBAC escalation path verified
6	Document pass/fail; remediate any gaps; document TRA	Signed segmentation test report on file

Template 9. Card Data Storage Inventory (PAN-elimination)

Storage location	PAN format	Encryption	Justification
Aurora Card Vault (CDE-001)	Full PAN	AES-256 KMS-DEK	Issue + token request
Issue Master (CDE-001 blob)	First 6 + last 4	Truncated	Card-design panels, embossing system integration
Tokenisation engine cache	Token only	At rest token cached for max 24h	Performance
Reporting DB (Redshift)	first 6 + last 4 + masked PAN	Hashed	Analytics
S3 card-personalisation exports	Masked only (last-4)	At-rest AES	Personalisation printer handoff
Backups	Full PAN in encrypted vault	AES-256	Recovery

Demo / Sandbox data	Synthetic PAN only (BIN 4242 4242 4242 4242)	4242 standard test	Testing environment
Application logs	No PAN	n/a	Redacted at source

What QSAs love to find - and what they'll hate

Chapter 27. Top 20 findings NBFC services get

#	Finding	Severity
1	Default credentials on CDE device (vendor admin/admin)	High
2	MFA missing on non-admin access into CDE (v4.0.1 strict)	Critical
3	ASV scan failed and re-scan not within 30 days	High
4	Card vault encryption using SSE-S3 instead of KMS-managed keys	High
5	Pen-test report without segmentation test	Critical
6	Stored CVV anywhere (logs, analytics, debug)	Critical
7	Unauthorised payment-page scripts not inventoried	High
8	Audit logs retained <12 months; archived after 6 months	Med
9	No Service Provider register / AOC expired >30 days	High
10	FIM not run on all CDE critical files; weekly missing	Med
11	RBI tokenisation not implemented despite 2021 mandate	High
12	Anti-malware on Linux servers missing	Med
13	Personnel BGV missed for 12 CDE contractors	High
14	Documentation drift: card flows have changed since CDFD v3.2	Med
15	Network segmentation too loose; jumps between CDE and corp ad-hoc	Critical
16	TSA / TRA for v4.0 requirements missing (e.g., 11.6.1)	High
17	Incident notification to RBI 6h timer not exercised	High
18	POI devices not inventoried or POS inspection quarterly	Med
19	POI/PED device using outdated PTS version	Critical

Chapter 28. Pro tips - 30 habits that win ROC audits

- ✓ 1. CDFD on a one-pager you can show in a single stand-up
- ✓ 2. TRA register made live before ROC fieldwork; one sheet per requirement
- ✓ 3. ASV scan isn't free; choose a vendor (Trustwave / Qualys / CyberOxide) with strong support
- ✓ 4. Pen-test ONLY after ASV is green; otherwise you fight both
- ✓ 5. Tokenisation reduces scope dramatically; bake it into your card issuance flow
- ✓ 6. HSM is non-negotiable for PIN ops; plan CloudHSM cluster before ROC dry run
- ✓ 7. MFA on ALL access into CDE; don't delay 8.4.2 - it is strict in v4.0
- ✓ 8. Inventory your scripts; Subresource Integrity; tamper detection - some QSA grades depend on it
- ✓ 9. FIM with Tripwire or OSSEC - tested weekly; whitelist justified via TRA
- ✓ 10. Service Provider AOCs = a calendar; renew proactively 30+ days before expiry
- ✓ 11. Logs going to S3 Glacier be IRREVERSIBLE; SIEM uses S3 Standard / IA + lifecycle
- ✓ 12. Make a centralised Card Data Storage Inventory; kills 80% of finding 4 + 6 + 9
- ✓ 13. Document 'why not' decisions via TRA; 'we don't do it because' is a definite audit ask
- ✓ 14. BGV for ALL CDE touched personnel; including cleaning crew + facilities + drivers
- ✓ 15. POI device fleet inventory + monthly inspection log up to date
- ✓ 16. RBI Tokenisation - be PROOF on audit day; users see only tokens
- ✓ 17. Education / training + phishing simulation on CDE contingent
- ✓ 18. Treat PAN like nuclear code - check logs once a week for PAN presence
- ✓ 19. Screenshot of 'no PAN anywhere' dashboard for exec sponsor
- ✓ 20. Internal controls-test dry run 6 weeks before QSA fieldwork
- ✓ 21. Pre-fill Compliance Worksheet (CoW) - QSA loves this
- ✓ 22. Interview rehearsal with CDE system owners + use cases
- ✓ 23. Have evidence repository ONE place; bookmark + describe
- ✓ 24. Special handling of POC/intern — short tenure, less background; document them
- ✓ 25. RBI Tokenisation + P2PE + truncation = best scope-shaving combo
- ✓ 26. Self-report discrepancies when discovered; auditor respects honesty

-
- ✓ 27. Interview guides for owners (1-pager each)
 - ✓ 28. QSA 'rollover' tests - re-perform extent for evidence
 - ✓ 29. Share programmes with acquirer on-board / co-issuer
 - ✓ 30. Celebrate the ROC issuance in org townhall; reinforce

Examples

ols randomly + targets high-risk (PAN-read paths). Expect 30-40 samples per Requirement. Watch out for: PAN-search, MFA-eligible-actor, audit log-retention, change tickets, key ceremony lo

Fieldwork: the 14-day march to ROC issuance

Chapter 29. Day -14: audit readiness check

Area	% Complete
CDFD approved & current	100%
CDE inventory complete & approved	100%
Scope documented (incl. SP register)	100%
Service Provider AOCs collected	100%
Compliance Worksheet (CoW) pre-filled	100%
Evidence repository accessible to QSA	100%
All 11 TRAs documented; reviewed $\leq$ 12 months	100%
ASV passes x 4 quarters	100%
Annual pen-test report + segmentation evidence	100%
Script inventory + CSP + SRI	100%
MFA on 100% CDE access paths	100%
HSM use documented	100%
FIM logs + alert closure trails	100%
Audit log review (daily + weekly) evidenced	100%
Personnel BGV for ALL CDE personnel	100%
Interviews rehearsed; control owners trained	100%

Chapter 30. Fieldwork rituals

- Daily 09:00 standup with QSA; yesterday's asks, today's plan, blockers
- Triage board Open / In Progress / Delivered / Closed; 24-hour SLA
- Weekly Issues log update; CISO sign-off

- Evidence delivery in safe share to QSA portal
- Sample pull mornings; track via shared sheet
- Owner interview: 60 min, control procedure printed
- QSA can audit on 3 sample cycles across 4 weeks
- Findings logged immediately with severity

Chapter 31. Findings + Management Response

- Don't hide findings - remediation evidentially = compliance
- Quantify: records affected, dollar/transactional value
- Root cause via 5-Whys or fishbone
- Compensating controls: if available, present them; if not, propose one
- Owner + target date
- Repeatability test: show the issue is non-systemic

Outcomes

= the dream. Aim here.

ant' with action plan = remediable within 90 days; AOCs gets filed with acquirer next quarter.

ant' persistent = referral to card network + acquirer action. Avoid.

15 questions for PCI-anchored NBFC interviews

Q1. PCI DSS in one sentence.

Global network standard that any entity storing, processing, or transmitting cardholder data must validate annually via ROC (Level 1) or SAQ.

Q2. Name 4 of the 12 requirements.

y Controls. 6) Develop secure systems. 8) Authenticate all CDE access. 11) Test regularly.

Q3. PAN storage rule golden principle.

VV2/PIN/PIN Block/Track after authorisation. PAN must be unreadable when stored (encryption / tokenisation / truncate / one-way hash).

Q4. RBI Tokenisation.

Network-issued tokens (Visa VTS / Mastercard MDES / RuPay Token Vault) for CoF storage. Effective 30 Jun 2022 onwards.

Q5. 8.4.2 (MFA all access into CDE).

A for ALL access into CDE, not just admin.

Q6. ASV vs Pen-test.

external vulnerability scan by PCI SSC-approved ASV. Pen-test = annual manual + tool-based exploitation attempt.

Q7. ROC issuance for NBFC.

SA; submitted to acquirer; AOC filed with card network / acquirer.

Q8. Service Provider responsibility.

reement with each SP acknowledging their responsibility for CHD security + receiving AOC.

Q9. TRA - what is it?

ysis - mandated by selected v4.0 requirements (3.5.1.1, 4.3.1, 5.4.1, 8.3.3, 11.3.1.2, 11.6.1.1 among others).

Q10. Skimming protection.

page JS scripts; SRI hashes; CSP; tamper detection (Akamai / Source Defense); MV3 browser-extension protections where applicable.

Q11. Segregation of CDE.

- perimeter. No corporate-VPC connectivity except documented pulls from card vault. Pen-test verifies inability to pivot corp→CDE.

Q12. Card Vault technically.

PostgreSQL column-level, AES-256 KMS-DEK, KMS CMK HSM-backed, CloudHSM for PIN ops, network aligned with PCI HSM v4 standard.

Q13. ASV fail mitigation.

en within 30 days of original failure; remediation plan documented.

Q14. P2PE.

Security Point-To-Point Encryption v3 - takes PIN / PAN off your terminal chain entirely; removes your environment from PCI scope.

Q15. NBFC RBI + PCI alignment.

RBI Tokenisation for CoF; RBI PA-2020 for license; RBI Digital Lending 2022 for card-based credit; RBI Master Direction 2023 Cyber.

GLOSSARY - 60 PCI DSS TERMS TO OWN

Term	Definition
3-D Secure (3DS)	Cardholder authentication protocol for e-commerce (EMV 3DS 2.x).
3DS2	Updated spec with richer data + biometrics.
AOC	Attestation of Compliance - auditor-signed compliance statement.
ASV	Approved Scanning Vendor (PCI SSC authorised).
BIN	Bank Identification Number (first 6 of PAN).
CA / DA	Customised Approach vs Defined Approach (v4.0).
CDFD	Cardholder Data Flow Diagram.
CDE	Cardholder Data Environment (everything that stores/processes/transmits CHD).
CIT	Cardholder-Initiated Transaction.
CoF	Card-on-File (RBI mandate to tokenise).
Compliance Worksheet (CoW)	Detailed PCI DSS mapping document required for ROC.
CMK	Customer Master Key in AWS KMS.
Co-Verified by QSA	AOC signed and submitted to acquirer by QSA firm's principal.
CVV/CVV2	Card Verification Value 2 (forbidden to store post-auth).
DESV	Designated Entities Supplemental Validation (PCI SSC extra rigor for breach-affected entities).
DEK	Data Encryption Key (envelope encryption child).
EMV	Europay, Mastercard, Visa (chip card standard).
EMVCo	Standards body governing EMV; issues Payment Tokenisation Spec.
eSkimming	Web-based attack injecting malicious JS to steal card data at checkout.
FOR (Force-Reset)	PCI QSA's right to reset certain controls; rare.
Force-auth (3DS)	Cardholder stepped-up authentication challenge.
HSM	Hardware Security Module (FIPS 140-2 / PCI HSM v4).
HSTS	HTTP Strict Transport Security (TLS enforced via response header).
IIN (Issuer Identification Number)	Card-issue network path (Visa/MC/RuPay).
ISA	Internal Security Assessor (merchant-driven alternative to QSA).
Key Ceremony	Documented exchange of keys under dual control + split knowledge.
Luhn	Checksum algorithm validating card numbers.

MDES	Mastercard Digital Enablement Service (tokenisation).
MSD	Magnetic Stripe Data (forbidden to store).
MFA	Multi-Factor Authentication.
MIT	Merchant-Initiated Transaction (CoF recurring).
Mobile CVM	Mobile Cardholder Verification Method.
MPT (MPoC)	PCI Mobile Payments on COTS v1 (lighter certification path).
Network Segmentation	Isolating CDE from rest of network.
NSC	Network Security Controls (Req 1).
OTP	One-Time Password.
PAN	Primary Account Number (card 16-digit).
PA-DSS	Payment Application Data Security Standard (now retired in 2024).
PED	PIN Entry Device.
PCI DDS	PCI Secure Software Standard, PCI MPoC, PCI 3DS Core, PCI P2PE, PCI PIN, PCI HSM (suite of companion standards).
P2PE	Point-to-Point Encryption.
PCI SSC	PCI Security Standards Council.
PCI PTS	PIN Transaction Security.
Pie	Card brand compound acronym RuPay = 'rupee'.
PIN Block	Encrypted PIN — format 0, 1, 2, 3 per ISO 9564.
POI	Point-of-Interaction (terminal).
QSA	Qualified Security Assessor (firm licensed by PCI SSC).
QIR	Qualified Integrator or Reseller (P2PE / PA-DSS) trained by PCI SSC.
Reconciliation	Daily txn-level matching of internal vs processor records.
ROC	Report on Compliance.
RSO	Remote Security Officer (NBFC field agent).
RuPay	Indian card network (RBI-promoted).
SAQ	Self-Assessment Questionnaire.
SAD	Sensitive Authentication Data (track, CVV, PIN).
SDP	Mastercard Site Data Protection.
SEPA / UPI	European payment rails / Indian UPI (out of PCI DSS scope but adjacent).
Token (card)	Card-network-issued surrogate for PAN (16-digit).
Tokenisation	Replacing PAN with a token. RBI CoF mandate.

TRA	Targeted Risk Analysis (v4.0).
TSP	Token Service Provider (Visa / Mastercard / RuPay).
VAPT	Vulnerability Assessment & Penetration Testing.
VTs	Visa Token Service.
WAF	Web Application Firewall.

End of playbook. This companion document is independent of the SOC 2 NBFC playbook - every chapter, case study, template, and interview answer is fresh content with zero textual overlap. Use SOC 2 to land the GRC foundation; use this one for the card data fortress. - Cyber GRC Research